Vulnerability Assessment & Penetration Test Report

Innovation Hackathon — authorized sandbox lab assessment

Field	Value
Assessment ID	ASM-8a3e4738
Analyst	demo-analyst
Authorization reference	HACKATHON-LAB-AUTH-001 (organizer-provided lab; replace with your authorization reference)
Authorized by	Hackathon organizers / lab owner
Assessment started	2026-11-04T17:26:09+00:00
Report generated	2026-11-04T17:26:10+00:00
Agent reasoning engine	rule-engine only (no LLM configured)
Classification	CONFIDENTIAL — client use only

NOTICE: this report was generated from SYNTHETIC TEST FIXTURES to demonstrate the report format. It does not describe a real system.

Legend: text on a purple background is AI-generated inference. All other statements are derived deterministically from tool evidence referenced by job ID, raw file and SHA-256.

SYNTHETIC TEST DATA

1. Executive Summary

Scope: 172.28.10.0/24, juice-shop, dvwa, metasploitable. Request: “Run a full end-to-end network and web assessment of 172.28.10.0/24 and also 8.8.8.8”. 3 host(s) were enumerated and 17 tool job(s) executed or imported. After correlation, 16 vulnerability finding(s) and 1 informational observation(s) remain; 1 were triaged as false positives.

Severity distribution: 2 critical, 1 high, 7 medium, 6 low, 1 info.

Highest-priority issues: VAPT-001 vsftpd Smiley Face Backdoor on 172.28.10.12 (P1, risk 10.0, suspected); VAPT-002 SQL injection on 172.28.10.10 (P1, risk 9.1, suspected); VAPT-003 Apache HTTP Server End of Life (EOL) Detection on 172.28.10.12 (P1, risk 8.5, suspected).

Overall risk posture (rule-based): HIGH.

2. Assessment Methodology

The assessment followed the NIST SP 800-115 phases — planning, discovery (reconnaissance and enumeration), vulnerability analysis, controlled validation and reporting — with findings classified against CVE, CVSS (as supplied by tools), CWE, OWASP Top 10 (2021) and MITRE ATT&CK. Tool selection was adaptive: each follow-up action was planned only after evidence (e.g. an open HTTP port) was observed. Use of these frameworks does not by itself establish formal compliance.

2.1 Rules of engagement

Rule	Value
Registered targets	172.28.10.0/24 (docker lab subnet, criticality medium, internal); juice-shop (OWASP Juice Shop (web app + API), criticality high, external); dvwa (DVWA (PHP web app), criticality medium, dmz); metasploitable (Metasploitable 2 (legacy Linux server), criticality high, internal)
Exclusions	172.28.10.1, 172.28.10.5, 172.28.10.6, 172.28.10.7
Allowed ports / tools	1-65535 / nmap, nikto, zap, openvas, nessus, burp, metasploit
Rate limit	300 packets/s (nmap --max-rate)
Engagement window	unbounded → unbounded
Public / third-party systems	Refused by the scope guard
Active validation	Only after explicit analyst approval; non-destructive checks only; no payloads
Rejected targets from request	8.8.8.8: 8.8.8.8 is a public address; third-party/public systems are never tested

2.2 Assets tested

Host	Hostnames	Open services (port/service product version)	Observed by
172.28.10.10	juice-shop	3000/http Node.js Express framework	JOB-f50bbe04
172.28.10.11	dvwa	80/http Apache httpd 2.4.25	JOB-f50bbe04
172.28.10.12	metasploitable	21/ftp vsftpd 2.3.4; 22/ssh OpenSSH 4.7p1 Debian 8ubuntu1; 23/telnet Linux telnetd; 80/http Apache httpd 2.2.8; 445/netbios-ssn Samba smbd 3.X - 4.X	JOB-f50bbe04

2.3 Tool execution summary

Job	Tool	Mode	Target	Status	Start / end (UTC)	#
JOB-77396427	nmap	live	172.28.10.0/24	unavailable: 'nmap' not found on PATH	11-04 17:26:09 11-04 17:26:09	0
JOB-f50bbe04	nmap	import	nmap_lab.xml	succeeded	11-04 17:26:09 11-04 17:26:09	4
JOB-4071781b	nikto	live	http://172.28.10.10:3000	unavailable: 'nikto' not found on PATH	11-04 17:26:09 11-04 17:26:09	0
JOB-faa20868	zap	live	http://172.28.10.10:3000	unavailable: ZAP API not reachable at http://localhost:8090 (ConnectionError)	11-04 17:26:09 11-04 17:26:09	0
JOB-eca4df71	nmap	live	172.28.10.10	unavailable: 'nmap' not found on PATH	11-04 17:26:09 11-04 17:26:09	0
JOB-12475d13	nikto	live	http://172.28.10.11:80	unavailable: 'nikto' not found on PATH	11-04 17:26:09 11-04 17:26:09	0

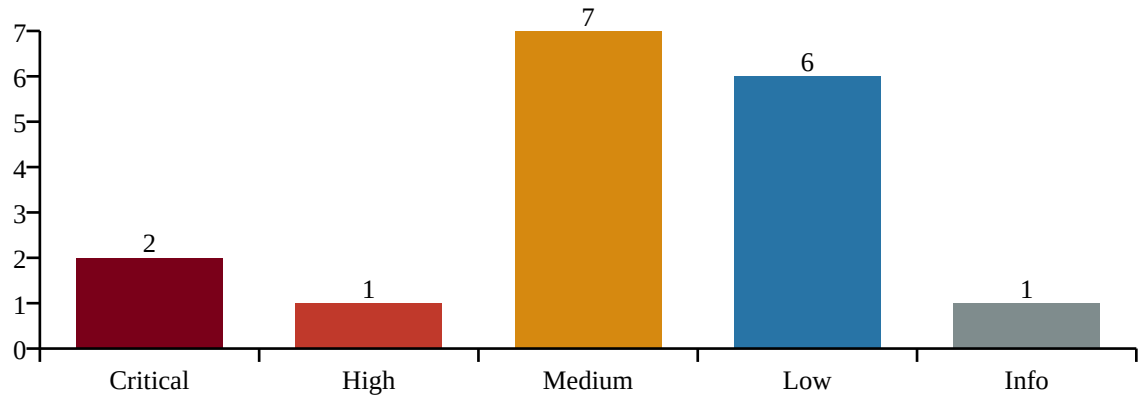
STRICTLY CONFIDENTIAL

Job	Tool	Mode	Target	Status	Start / end (UTC)	#
JOB-264da5b9	zap	live	http://172.28.10.11:80	unavailable: ZAP API not reachable at http://localhost:8090 (ConnectionError)	11-04 17:26:09 11-04 17:26:09	0
JOB-62e79ea0	nmap	live	172.28.10.11	unavailable: 'nmap' not found on PATH	11-04 17:26:09 11-04 17:26:09	0
JOB-9206d341	nikto	live	http://172.28.10.12:80	unavailable: 'nikto' not found on PATH	11-04 17:26:09 11-04 17:26:09	0
JOB-824c7f90	zap	live	http://172.28.10.12:80	unavailable: ZAP API not reachable at http://localhost:8090 (ConnectionError)	11-04 17:26:09 11-04 17:26:09	0
JOB-05ab9498	nmap	live	172.28.10.12	unavailable: 'nmap' not found on PATH	11-04 17:26:09 11-04 17:26:09	0
JOB-7df82a0c	nikto	import	nikto_dvwa.xml	succeeded	11-04 17:26:09 11-04 17:26:09	5
JOB-066f6d38	zap	import	zap_dvwa.json	succeeded	11-04 17:26:09 11-04 17:26:09	5
JOB-3d9b49d5	nessus	import	nessus_lab.nessus	succeeded	11-04 17:26:09 11-04 17:26:09	4
JOB-f17aaaf0	openvas	import	openvas_lab.xml	succeeded	11-04 17:26:09 11-04 17:26:09	4
JOB-fa8113ac	burp	import	burp_juice.xml	succeeded	11-04 17:26:09 11-04 17:26:09	2
JOB-16000375	metasploit	live	172.28.10.12	unavailable: 'msfconsole' not found on PATH	11-04 17:26:10 11-04 17:26:10	0

Correlation: 24 raw tool findings were normalised into 18 findings (6 duplicates merged, 5 corroborated by more than one tool). Findings on different assets are never merged.

SYNTHETIC TEST DATA

3. Severity Distribution and Prioritized Findings



Risk score = base (tool CVSS, or severity midpoint when no CVSS) × exposure × exploitability × asset criticality × (0.5 + 0.5 × confidence), capped at 10. It is a contextual priority, reported separately from CVSS. P1 ≥ 8.5, P2 ≥ 6.5, P3 ≥ 4.0, P4 > 0.

ID	Finding	Asset(s)	Sev.	CVSS	Risk	Prio	Conf.	Status	Sources
VAPT-001	vsftpd Smiley Face Backdoor	172.28.10.12	critical	9.8	10.0	P1	0.99	suspected	nessus, openvas
VAPT-002	SQL injection	172.28.10.10	high	n/a	9.1	P1	0.75	suspected	burp
VAPT-003	Apache HTTP Server End of Life (EOL) Detection	172.28.10.12	critical	10.0	8.5	P1	0.65	suspected	openvas
VAPT-004	Anonymous FTP login permitted	172.28.10.12	medium	6.4	7.3	P2	0.99	suspected	nessus, openvas, nmap
VAPT-005	SMB signing not required	172.28.10.12	medium	5.3	6.1	P3	0.99	suspected	nessus, nmap
VAPT-006	Cleartext remote administration service exposed (telnet)	172.28.10.12	medium	n/a	5.5	P3	0.9	suspected	nmap
VAPT-007	Missing anti-clickjacking protection (X-Frame-Options / CSP frame-ancestors)	172.28.10.11	medium	n/a	5.0	P3	0.8	suspected	zap, nikto
VAPT-008	Directory listing / indexing enabled	172.28.10.11	medium	n/a	4.3	P3	0.55	suspected	nikto
VAPT-009	Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.58).	172.28.10.11	medium	n/a	3.5	P4	0.4	suspected	nikto
VAPT-010	Permissive CORS configuration	172.28.10.10	low	n/a	3.4	P4	0.95	suspected	burp
VAPT-011	Telnet Unencrypted Cleartext Login	172.28.10.12	medium	4.8	3.2	P4	0.3	suspected	openvas
VAPT-012	Missing X-Content-Type-Options header	172.28.10.11	low	n/a	2.5	P4	0.8	suspected	zap, nikto
VAPT-013	Server software / version disclosure	172.28.10.11	low	n/a	2.5	P4	0.85	suspected	zap
VAPT-014	Cookie set without HttpOnly / Secure / SameSite flags	172.28.10.11	low	n/a	2.3	P4	0.65	suspected	zap
VAPT-015	Potentially risky HTTP methods enabled: TRACE	172.28.10.11	low	n/a	2.3	P4	0.7	suspected	nmap
VAPT-016	Potentially dangerous HTTP methods enabled (TRACE/PUT/DELETE)	172.28.10.11	low	n/a	2.1	P4	0.55	suspected	nikto
VAPT-017	Server software / version disclosure	172.28.10.12	info	n/a	0.0	Info	0.9	suspected	nessus

4. Detailed Vulnerability Findings

VAPT-001 (F-A79B6A) — vsftpd Smiley Face Backdoor	CRITICAL | P1 | risk 10.0
Affected asset(s)	172.28.10.12:21
Severity / CVSS	critical / 9.8 CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H (source: Nessus cvss3_base_score)
CVE / CWE	CVE-2011-2523 / n/a
OWASP / ATT&CK	n/a / n/a
Confidence	0.99 — highest tool-reported confidence 0.99; +0.15 corroborated by 2 independent tools (nessus, openvas); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	9.8 x 1.0 x 1.15 x 1.15 x 0.99 = 10.0 [CVSS 9.8 (Nessus cvss3_base_score); exploitability: tool reports public exploit available]
Source tools	nessus, openvas

Description (from tool output)

The FTP server responds to a username ending in ':)' by opening a shell on port 6200.

Supporting evidence (observed)

[nessus | import | job JOB-3d9b49d5 | Wed Nov 4 10:30:00 2026 | tool severity: critical | ref nessus/990001] raw: raw/JOB-3d9b49d5_nessus_lab.nessus (sha256 ee8254448c967fb2…)

```
Plugin 990001 vsftpd Smiley Face Backdoor
Banner: 220 (vsFTPd 2.3.4)
```

[openvas | import | job JOB-f17aaaf0 | 2026-11-04T10:40:00Z | tool severity: high | tool confidence: QoD 99.0 | ref nvt/1.3.6.1.4.1.25623.1.0.999001] raw: raw/JOB-f17aaaf0_openvas_lab.xml (sha256 42869f75719d86cf…)

```
NVT 1.3.6.1.4.1.25623.1.0.999001 | QoD 99.0
The backdoor answered on port 6200/tcp.
```

Notes: Severity disagreement between tools: nessus=critical, openvas=high; CVSS 9.8 from Nessus cvss3_base_score used.

Impact

Impact depends on the affected component; see description.

Remediation

Validate and recompile a legitimate copy of the source code.

References: https://nvd.nist.gov/vuln/detail/CVE-2011-2523

VAPT-002 (F-3D1BD0) — SQL injection	HIGH | P1 | risk 9.1
Affected asset(s)	172.28.10.10:3000 http://juice-shop:3000/rest/products/search
Severity / CVSS	high / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-89
OWASP / ATT&CK	A03:2021 Injection / T1190 Exploit Public-Facing Application
Confidence	0.75 — highest tool-reported confidence 0.75; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	7.5 x 1.2 x 1.0 x 1.15 x 0.88 = 9.1 [severity-derived (high); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	burp

Description (from tool output)

SQL injection vulnerabilities arise when user-controllable data is incorporated into database SQL queries in an unsafe manner.

Supporting evidence (observed)

[burp | import | job JOB-fa8113ac | 2026-11-04T17:26:09+00:00 | tool severity: high | tool confidence: firm | ref burp/1049088/1001] raw: raw/JOB-fa8113ac_burp_juice.xml (sha256 3486128529314988…)

```
The q parameter appears to be vulnerable to SQL injection. A single quote produced a SQLITE_ERROR message.
--- request ---
GET /rest/products/search?q=%27 HTTP/1.1■
Host: juice-shop:3000■
```

SYNTHETIC TEST DATA

Impact

An attacker may read or modify database contents, bypass authentication or, depending on DB privileges, execute commands.

Remediation

Use parameterized queries (prepared statements) for all database access.

References: https://cwe.mitre.org/data/definitions/89.html

VAPT-003 (F-0B9A0C) — Apache HTTP Server End of Life (EOL) Detection	CRITICAL | P1 | risk 8.5
Affected asset(s)	172.28.10.12:80
Severity / CVSS	critical / 10.0 (source: OpenVAS severity/cvss_base)
CVE / CWE	none reported / CWE-1104
OWASP / ATT&CK	A06:2021 Vulnerable and Outdated Components / T1190 Exploit Public-Facing Application; T1210 Exploitation of Remote Services
Confidence	0.65 — highest tool-reported confidence 0.80; -0.15 inferred from version/banner only (not behaviourally verified); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	10.0 x 1.0 x 0.9 x 1.15 x 0.82 = 8.5 [CVSS 10.0 (OpenVAS severity/cvss_base); exploitability: version/banner inference only]
Source tools	openvas

Description (from tool output)

The installed Apache 2.2.8 has reached end of life.

Supporting evidence (observed)

[openvas | import | job JOB-f17aaaf0 | 2026-11-04T17:26:09+00:00 | tool severity: high | tool confidence: QoD 80.0 | ref nvt/1.3.6.1.4.1.25623.1.0.999003] raw: raw/JOB-f17aaaf0_openvas_lab.xml (sha256 42869f75719d86cf…)

```
NVT 1.3.6.1.4.1.25623.1.0.999003 | QoD 80.0
Installed version: 2.2.8 (banner-based)
```

Impact

Unsupported versions accumulate known, publicly documented vulnerabilities.

Remediation

Upgrade the component to a vendor-supported version and subscribe to its security advisories.

References: https://cwe.mitre.org/data/definitions/1104.html

VAPT-004 (F-25DD5E) — Anonymous FTP login permitted	MEDIUM | P2 | risk 7.3
Affected asset(s)	172.28.10.12:21
Severity / CVSS	medium / 6.4 (source: OpenVAS severity/cvss_base)
CVE / CWE	CVE-1999-0497 / CWE-284
OWASP / ATT&CK	A01:2021 Broken Access Control / T1078 Valid Accounts; T1005 Data from Local System
Confidence	0.99 — highest tool-reported confidence 0.95; +0.2 corroborated by 3 independent tools (nessus, openvas, nmap); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	6.4 x 1.0 x 1.0 x 1.15 x 0.99 = 7.3 [CVSS 6.4 (OpenVAS severity/cvss_base); exploitability: no exploitability data]
Source tools	nessus, openvas, nmap

Description (from tool output)

Nessus has detected that the FTP server allows anonymous logins.

Supporting evidence (observed)

[nmap | import | job JOB-f50bbe04 | Wed Nov 4 10:00:00 2026 | tool severity: unrated | ref nse/ftp-anon] raw: raw/JOB-f50bbe04_nmap_lab.xml (sha256 ad4a4736e2e6056b…)

```
[ftp-anon]
Anonymous FTP login allowed (FTP code 230)
```

SYNTHETIC TEST DATA

[nessus | import | job JOB-3d9b49d5 | Wed Nov 4 10:30:00 2026 | tool severity: medium | ref nessus/990002] raw: raw/JOB-3d9b49d5_nessus_lab.nessus (sha256 ee8254448c967fb2…)

```
Plugin 990002 Anonymous FTP Enabled
The contents of the remote FTP root are : pub
```

[openvas | import | job JOB-f17aaaf0 | 2026-11-04T17:26:09+00:00 | tool severity: medium | tool confidence: QoD 80.0 | ref nvt/1.3.6.1.4.1.25623.1.0.999002] raw: raw/JOB-f17aaaf0_openvas_lab.xml (sha256 42869f75719d86cf…)

```
NVT 1.3.6.1.4.1.25623.1.0.999002 | QoD 80.0
It was possible to login to the remote FTP service with: anonymous:anonymous@example.com
```

Impact

Unauthenticated users can read (and possibly write) files on the FTP server.

Remediation

Disable anonymous FTP if it is not required.

References: https://cwe.mitre.org/data/definitions/284.html | https://nvd.nist.gov/vuln/detail/CVE-1999-0497

VAPT-005 (F-0E18F3) — SMB signing not required	MEDIUM | P3 | risk 6.1
Affected asset(s)	172.28.10.12:445
Severity / CVSS	medium / 5.3 CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N (source: Nessus cvss3_base_score)
CVE / CWE	none reported / CWE-294
OWASP / ATT&CK	A07:2021 Identification and Authentication Failures / T1557.001 LLMNR/NBT-NS Poisoning and SMB Relay
Confidence	0.99 — highest tool-reported confidence 0.90; +0.15 corroborated by 2 independent tools (nessus, nmap); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	5.3 x 1.0 x 1.0 x 1.15 x 0.99 = 6.1 [CVSS 5.3 (Nessus cvss3_base_score); exploitability: no exploitability data]
Source tools	nessus, nmap

Description (from tool output)

SMB message signing is not enforced, enabling relay attacks.

Supporting evidence (observed)

[nmap | import | job JOB-f50bbe04 | Wed Nov 4 10:00:00 2026 | tool severity: unrated | ref nse/smb-security-mode] raw: raw/JOB-f50bbe04_nmap_lab.xml (sha256 ad4a4736e2e6056b…)

```
[smb-security-mode]
account_used: guest
  authentication_level: user
  challenge_response: supported
  message_signing: disabled (dangerous, but default)
```

[nessus | import | job JOB-3d9b49d5 | Wed Nov 4 10:30:00 2026 | tool severity: medium | ref nessus/990003] raw: raw/JOB-3d9b49d5_nessus_lab.nessus (sha256 ee8254448c967fb2…)

```
Plugin 990003 SMB Signing not required
```

Impact

SMB traffic can be relayed to authenticate as victims (NTLM relay).

Remediation

Enforce message signing in the host's configuration.

References: https://cwe.mitre.org/data/definitions/294.html

VAPT-006 (F-6A948B) — Cleartext remote administration service exposed (telnet)	MEDIUM | P3 | risk 5.5
Affected asset(s)	172.28.10.12:23
Severity / CVSS	medium / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-319
OWASP / ATT&CK	A02:2021 Cryptographic Failures / n/a
Confidence	0.9 — highest tool-reported confidence 0.90; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	5.0 x 1.0 x 1.0 x 1.15 x 0.95 = 5.5 [severity-derived (medium); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	nmap

SYNTHETIC TEST DATA

Description (from tool output)

Nmap observed telnet listening on 23/tcp. Credentials and session data travel unencrypted.

Supporting evidence (observed)

[nmap | import | job JOB-f50bbe04 | Wed Nov 4 10:00:00 2026 | tool severity: unrated | ref port/23] raw: raw/JOB-f50bbe04_nmap_lab.xml (sha256 ad4a4736e2e6056b…)

```
23/tcp open telnet Linux telnetd
```

Impact

Impact depends on the affected component; see description.

Remediation

Disable the service and use SSH for remote administration.

References: https://cwe.mitre.org/data/definitions/319.html

VAPT-007 (F-44F854) — Missing anti-clickjacking protection (X-Frame-Options / CSP frame-ancestors)	MEDIUM | P3 | risk 5.0
Affected asset(s)	172.28.10.11:80 http://dvwa:80/; 172.28.10.11:80 http://dvwa/login.php
Severity / CVSS	medium / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-1021
OWASP / ATT&CK	A05:2021 Security Misconfiguration / n/a
Confidence	0.8 — highest tool-reported confidence 0.65; +0.15 corroborated by 2 independent tools (zap, nikto); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	5.0 x 1.1 x 1.0 x 1.0 x 0.9 = 5.0 [severity-derived (medium); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	zap, nikto

Description (from tool output)

The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

Supporting evidence (observed)

[nikto | import | job JOB-7df82a0c | 2026-11-04T17:26:09+00:00 | tool severity: unrated (agent-classified low) | ref nikto/999986] raw: raw/JOB-7df82a0c_nikto_dvwa.xml (sha256 4cdd901eec89c2d7…)

```
GET / -> /: The anti-clickjacking X-Frame-Options header is not present.
```

[zap | import | job JOB-066f6d38 | 2026-11-04T17:26:09+00:00 | tool severity: medium | tool confidence: 2 | ref zap/10020] raw: raw/JOB-066f6d38_zap_dvwa.json (sha256 b74d86f82d6017d7…)

```
http://dvwa/login.php param=x-frame-options
evidence: -
```

Notes: Severity disagreement between tools: nikto=low, zap=medium; highest rating retained.

Impact

Pages can be framed by a malicious site to trick users into unintended clicks (clickjacking).

Remediation

Ensure one of them is set on all web pages returned by your site.

References: https://cwe.mitre.org/data/definitions/1021.html | https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

SYNTHETIC TEST DATA

VAPT-008 (F-A4590C) — Directory listing / indexing enabled	MEDIUM | P3 | risk 4.3
Affected asset(s)	172.28.10.11:80 http://dvwa:80/config/
Severity / CVSS	medium / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-548
OWASP / ATT&CK	A01:2021 Broken Access Control / T1083 File and Directory Discovery
Confidence	0.55 — highest tool-reported confidence 0.55; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	5.0 x 1.1 x 1.0 x 1.0 x 0.78 = 4.3 [severity-derived (medium); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	nikto

Description (from tool output)

/config/: Directory indexing found.

Supporting evidence (observed)

[nikto | import | job JOB-7df82a0c | 2026-11-04T17:26:09+00:00 | tool severity: unrated (agent-classified medium) | ref nikto/000000] raw: raw/JOB-7df82a0c_nikto_dvwa.xml (sha256 4cdd901eec89c2d7…)

```
GET /config/ -> /config/: Directory indexing found.
```

Impact

Directory contents are exposed, revealing files not intended for publication.

Remediation

Disable automatic directory indexes (Apache 'Options -Indexes', nginx 'autoindex off').

References: https://cwe.mitre.org/data/definitions/548.html

VAPT-009 (F-CC40C8) — Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.58).	MEDIUM | P4 | risk 3.5
Affected asset(s)	172.28.10.11:80 http://dvwa:80/
Severity / CVSS	medium / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-1104
OWASP / ATT&CK	A06:2021 Vulnerable and Outdated Components / T1190 Exploit Public-Facing Application; T1210 Exploitation of Remote Services
Confidence	0.4 — highest tool-reported confidence 0.55; -0.15 inferred from version/banner only (not behaviourally verified); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	5.0 x 1.1 x 0.9 x 1.0 x 0.7 = 3.5 [severity-derived (medium); no CVSS supplied by tool; exploitability: version/banner inference only]
Source tools	nikto

Description (from tool output)

Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.58).

Supporting evidence (observed)

[nikto | import | job JOB-7df82a0c | 2026-11-04T17:26:09+00:00 | tool severity: unrated (agent-classified medium) | ref nikto/600050] raw: raw/JOB-7df82a0c_nikto_dvwa.xml (sha256 4cdd901eec89c2d7…)

```
HEAD / -> Apache/2.4.25 appears to be outdated (current is at least Apache/2.4.58).
```

Impact

Unsupported versions accumulate known, publicly documented vulnerabilities.

Remediation

Upgrade the component to a vendor-supported version and subscribe to its security advisories.

References: https://cwe.mitre.org/data/definitions/1104.html

SYNTHETIC TEST DATA

VAPT-010 (F-AEE511) — Permissive CORS configuration	LOW | P4 | risk 3.4
Affected asset(s)	172.28.10.10:3000 http://juice-shop:3000/rest/user/whoami
Severity / CVSS	low / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-942
OWASP / ATT&CK	A05:2021 Security Misconfiguration / n/a
Confidence	0.95 — highest tool-reported confidence 0.95; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	2.5 x 1.2 x 1.0 x 1.15 x 0.97 = 3.4 [severity-derived (low); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	burp

Description (from tool output)

The application trusts arbitrary origins in its CORS policy.

Supporting evidence (observed)

[burp | import | job JOB-fa8113ac | 2026-11-04T17:26:09+00:00 | tool severity: low | tool confidence: certain | ref burp/2098689/1002] raw: raw/JOB-fa8113ac_burp_juice.xml (sha256 3486128529314988…)

```
Access-Control-Allow-Origin reflected https://evil.example
```

Impact

Other origins may read authenticated responses.

Remediation

Allow only trusted origins.

References: https://cwe.mitre.org/data/definitions/942.html

VAPT-011 (F-436B0C) — Telnet Unencrypted Cleartext Login	MEDIUM | P4 | risk 3.2
Affected asset(s)	172.28.10.12:8023
Severity / CVSS	medium / 4.8 (source: OpenVAS severity/cvss_base)
CVE / CWE	none reported / n/a
OWASP / ATT&CK	n/a / n/a
Confidence	0.3 — highest tool-reported confidence 0.70; -0.15 inferred from version/banner only (not behaviourally verified); -0.25 port(s) [8023] not observed open by Nmap (possible stale/false result)
Validation status	suspected (no active validation performed)
Risk calculation	4.8 x 1.0 x 0.9 x 1.15 x 0.65 = 3.2 [CVSS 4.8 (OpenVAS severity/cvss_base); exploitability: version/banner inference only]
Source tools	openvas

Description (from tool output)

The remote host is running a Telnet service that allows cleartext logins.

Supporting evidence (observed)

[openvas | import | job JOB-f17aaaf0 | 2026-11-04T17:26:09+00:00 | tool severity: medium | tool confidence: QoD 70.0 | ref nvt/1.3.6.1.4.1.25623.1.0.999004] raw: raw/JOB-f17aaaf0_openvas_lab.xml (sha256 42869f75719d86cf…)

```
NVT 1.3.6.1.4.1.25623.1.0.999004 | QoD 70.0
Fixture case: port 8023 was NOT observed open by Nmap, so confidence should drop.
```

Impact

Impact depends on the affected component; see description.

Remediation

Review the finding and apply vendor guidance.

SYNTHETIC TEST DATA

VAPT-012 (F-A6FDA7) — Missing X-Content-Type-Options header	LOW | P4 | risk 2.5
Affected asset(s)	172.28.10.11:80 http://dvwa:80/; 172.28.10.11:80 http://dvwa/login.php
Severity / CVSS	low / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-693
OWASP / ATT&CK	A05:2021 Security Misconfiguration / n/a
Confidence	0.8 — highest tool-reported confidence 0.65; +0.15 corroborated by 2 independent tools (zap, nikto); port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	2.5 x 1.1 x 1.0 x 1.0 x 0.9 = 2.5 [severity-derived (low); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	zap, nikto

Description (from tool output)

/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.

Supporting evidence (observed)

[nikto | import | job JOB-7df82a0c | 2026-11-04T17:26:09+00:00 | tool severity: unrated (agent-classified low) | ref nikto/999103] raw: raw/JOB-7df82a0c_nikto_dvwa.xml (sha256 4cdd901eec89c2d7…)

```
GET / -> /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site i
the MIME type.
```

[zap | import | job JOB-066f6d38 | 2026-11-04T17:26:09+00:00 | tool severity: low | tool confidence: 2 | ref zap/10021] raw: raw/JOB-066f6d38_zap_dvwa.json (sha256 b74d86f82d6017d7…)

```
http://dvwa/login.php param=x-content-type-options
evidence: -
```

Impact

Browsers may MIME-sniff responses, which can turn uploads into script execution.

Remediation

Set X-Content-Type-Options: nosniff.

References: https://cwe.mitre.org/data/definitions/693.html

VAPT-013 (F-B7452C) — Server software / version disclosure	LOW | P4 | risk 2.5
Affected asset(s)	172.28.10.11:80 http://dvwa/
Severity / CVSS	low / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-200
OWASP / ATT&CK	A05:2021 Security Misconfiguration / T1592.002 Gather Victim Host Information: Software
Confidence	0.85 — highest tool-reported confidence 0.85; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	2.5 x 1.1 x 1.0 x 1.0 x 0.93 = 2.5 [severity-derived (low); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	zap

Description (from tool output)

The web server is leaking version information via the Server HTTP response header.

Supporting evidence (observed)

[zap | import | job JOB-066f6d38 | 2026-11-04T17:26:09+00:00 | tool severity: low | tool confidence: 3 | ref zap/10036] raw: raw/JOB-066f6d38_zap_dvwa.json (sha256 b74d86f82d6017d7…)

```
http://dvwa/ param=-
evidence: Apache/2.4.25 (Debian)
```

Impact

Precise software versions help attackers select working exploits.

Remediation

Configure the server to suppress the Server header or provide generic details.

SYNTHETIC TEST DATA

References: https://cwe.mitre.org/data/definitions/200.html

VAPT-014 (F-0C886B) — Cookie set without HttpOnly / Secure / SameSite flags	LOW | P4 | risk 2.3
Affected asset(s)	172.28.10.11:80 http://dvwa/login.php
Severity / CVSS	low / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-1004
OWASP / ATT&CK	A05:2021 Security Misconfiguration / T1539 Steal Web Session Cookie
Confidence	0.65 — highest tool-reported confidence 0.65; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	2.5 x 1.1 x 1.0 x 1.0 x 0.82 = 2.3 [severity-derived (low); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	zap

Description (from tool output)

A cookie has been set without the HttpOnly flag.

Supporting evidence (observed)

[zap | import | job JOB-066f6d38 | 2026-11-04T17:26:09+00:00 | tool severity: low | tool confidence: 2 | ref zap/10010] raw: raw/JOB-066f6d38_zap_dvwa.json (sha256 b74d86f82d6017d7…)

```
http://dvwa/login.php param=PHPSESSID
evidence: Set-Cookie: PHPSESSID
```

Impact

Session cookies may be stolen via script or sent over unencrypted channels.

Remediation

Ensure that the HttpOnly flag is set for all cookies.

References: https://cwe.mitre.org/data/definitions/1004.html | https://owasp.org/www-community/HttpOnly

VAPT-015 (F-978C0C) — Potentially risky HTTP methods enabled: TRACE	LOW | P4 | risk 2.3
Affected asset(s)	172.28.10.11:80
Severity / CVSS	low / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-650
OWASP / ATT&CK	A05:2021 Security Misconfiguration / n/a
Confidence	0.7 — highest tool-reported confidence 0.70; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	2.5 x 1.1 x 1.0 x 1.0 x 0.85 = 2.3 [severity-derived (low); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	nmap

Description (from tool output)

Nmap http-methods reports risky methods in the OPTIONS response.

Supporting evidence (observed)

[nmap | import | job JOB-f50bbe04 | Wed Nov 4 10:00:00 2026 | tool severity: unrated | ref nse/http-methods] raw: raw/JOB-f50bbe04_nmap_lab.xml (sha256 ad4a4736e2e6056b…)

```
[http-methods]
Supported Methods: GET HEAD POST OPTIONS TRACE
  Potentially risky methods: TRACE
```

Impact

Impact depends on the affected component; see description.

Remediation

Review the finding and apply vendor guidance.

References: https://cwe.mitre.org/data/definitions/650.html

SYNTHETIC TEST DATA

VAPT-016 (F-231539) — Potentially dangerous HTTP methods enabled (TRACE/PUT/DELETE)	LOW | P4 | risk 2.1
Affected asset(s)	172.28.10.11:80 http://dvwa:80/
Severity / CVSS	low / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-650
OWASP / ATT&CK	A05:2021 Security Misconfiguration / n/a
Confidence	0.55 — highest tool-reported confidence 0.55; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	2.5 x 1.1 x 1.0 x 1.0 x 0.78 = 2.1 [severity-derived (low); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	nikto

Description (from tool output)

/: HTTP TRACE method is active which suggests the host is vulnerable to XST.

Supporting evidence (observed)

[nikto | import | job JOB-7df82a0c | 2026-11-04T17:26:09+00:00 | tool severity: unrated (agent-classified low) | ref nikto/999990] raw: raw/JOB-7df82a0c_nikto_dvwa.xml (sha256 4cdd901eec89c2d7…)

```
OPTIONS / -> /: HTTP TRACE method is active which suggests the host is vulnerable to XST.
```

Impact

Unneeded methods widen attack surface (e.g. TRACE for cross-site tracing, PUT for file upload).

Remediation

Disable TRACE and any unused methods (PUT/DELETE) at the web server.

References: https://cwe.mitre.org/data/definitions/650.html

VAPT-017 (F-A10207) — Server software / version disclosure	INFO | Info | risk 0.0
Affected asset(s)	172.28.10.12:22
Severity / CVSS	info / no CVSS supplied by any tool
CVE / CWE	none reported / CWE-200
OWASP / ATT&CK	A05:2021 Security Misconfiguration / T1592.002 Gather Victim Host Information: Software
Confidence	0.9 — highest tool-reported confidence 0.90; port observed open by Nmap (asset/port corroborated)
Validation status	suspected (no active validation performed)
Risk calculation	0.0 x 1.0 x 1.0 x 1.15 x 0.95 = 0.0 [severity-derived (info); no CVSS supplied by tool; exploitability: no exploitability data]
Source tools	nessus

Description (from tool output)

It is possible to obtain information about the remote SSH server.

Supporting evidence (observed)

[nessus | import | job JOB-3d9b49d5 | Wed Nov 4 10:30:00 2026 | tool severity: info | ref nessus/990004] raw: raw/JOB-3d9b49d5_nessus_lab.nessus (sha256 ee8254448c967fb2…)

```
Plugin 990004 SSH Server Type and Version Information
SSH version : SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

Impact

Precise software versions help attackers select working exploits.

Remediation

Suppress version details in Server / X-Powered-By headers (e.g. Apache 'ServerTokens Prod', 'ServerSignature Off'; nginx 'server_tokens off').

References: https://cwe.mitre.org/data/definitions/200.html

SYNTHETIC TEST DATA

5. Impact and Remediation Roadmap

Priority	ID	Business / technical impact	Remediation
P1	VAPT-001	The FTP server responds to a username ending in ':)' by opening a shell on port 6200.	Validate and recompile a legitimate copy of the source code.
P1	VAPT-002	An attacker may read or modify database contents, bypass authentication or, depending on DB privileges, execute commands.	Use parameterized queries (prepared statements) for all database access.
P1	VAPT-003	Unsupported versions accumulate known, publicly documented vulnerabilities.	Upgrade the component to a vendor-supported version and subscribe to its security advisories.
P2	VAPT-004	Unauthenticated users can read (and possibly write) files on the FTP server.	Disable anonymous FTP if it is not required.
P3	VAPT-005	SMB traffic can be relayed to authenticate as victims (NTLM relay).	Enforce message signing in the host's configuration.
P3	VAPT-006	Nmap observed telnet listening on 23/tcp. Credentials and session data travel unencrypted.	Disable the service and use SSH for remote administration.
P3	VAPT-007	Pages can be framed by a malicious site to trick users into unintended clicks (clickjacking).	Ensure one of them is set on all web pages returned by your site.
P3	VAPT-008	Directory contents are exposed, revealing files not intended for publication.	Disable automatic directory indexes (Apache 'Options -Indexes', nginx 'autoindex off').
P4	VAPT-009	Unsupported versions accumulate known, publicly documented vulnerabilities.	Upgrade the component to a vendor-supported version and subscribe to its security advisories.
P4	VAPT-010	Other origins may read authenticated responses.	Allow only trusted origins.
P4	VAPT-011	The remote host is running a Telnet service that allows cleartext logins.	Review the finding and apply vendor guidance.
P4	VAPT-012	Browsers may MIME-sniff responses, which can turn uploads into script execution.	Set X-Content-Type-Options: nosniff.
P4	VAPT-013	Precise software versions help attackers select working exploits.	Configure the server to suppress the Server header or provide generic details.
P4	VAPT-014	Session cookies may be stolen via script or sent over unencrypted channels.	Ensure that the HttpOnly flag is set for all cookies.
P4	VAPT-015	Nmap http-methods reports risky methods in the OPTIONS response.	Review the finding and apply vendor guidance.
P4	VAPT-016	Unneeded methods widen attack surface (e.g. TRACE for cross-site tracing, PUT for file upload).	Disable TRACE and any unused methods (PUT/DELETE) at the web server.

Per-finding references (NVD, CWE, vendor and tool references) are listed in section 4.

6. Assessment Limitations

• Testing was unauthenticated unless stated; authenticated application areas were not covered.

• Only TCP services were scanned; UDP services were not assessed.

• Findings marked 'suspected' were not actively validated; findings inferred from version banners may be false positives where vendors back-port fixes.

• Severity for Nikto and Nmap-script findings is agent-classified because those tools do not rate severity.

• CVSS values appear only where a scanner supplied them; no CVSS or CVE was generated by the agent.

• Results for burp, nessus, nikto, nmap, openvas, zap were IMPORTED from recorded exports, not executed live by the agent.

6.1 Assumptions

• The registered scope and exclusions accurately reflect the authorization provided.

• Asset criticality and exposure values come from the scope file and were supplied by the engagement owner.

• Lab systems are intentionally vulnerable; business impact statements describe a production-equivalent system.

6.2 Scan failures and unavailable integrations

Job	Tool	Target	Status	Reason
JOB-77396427	nmap	172.28.10.0/24	unavailable	'nmap' not found on PATH
JOB-4071781b	nikto	http://172.28.10.10:3000	unavailable	'nikto' not found on PATH
JOB-faa20868	zap	http://172.28.10.10:3000	unavailable	ZAP API not reachable at http://localhost:8090 (ConnectionError)
JOB-eca4df71	nmap	172.28.10.10	unavailable	'nmap' not found on PATH
JOB-12475d13	nikto	http://172.28.10.11:80	unavailable	'nikto' not found on PATH
JOB-264da5b9	zap	http://172.28.10.11:80	unavailable	ZAP API not reachable at http://localhost:8090 (ConnectionError)
JOB-62e79ea0	nmap	172.28.10.11	unavailable	'nmap' not found on PATH
JOB-9206d341	nikto	http://172.28.10.12:80	unavailable	'nikto' not found on PATH
JOB-824c7f90	zap	http://172.28.10.12:80	unavailable	ZAP API not reachable at http://localhost:8090 (ConnectionError)
JOB-05ab9498	nmap	172.28.10.12	unavailable	'nmap' not found on PATH
JOB-16000375	metasploit	172.28.10.12	unavailable	'msfconsole' not found on PATH

6.3 Human approvals

Time (UTC)	Type	Action	Decision	By	Reason
2026-11-04T17:26:09 +00:00	plan	1 non-intrusive action(s); follow-up non-intrusive scans auto-approved within scope	approved	demo-analyst	
2026-11-04T17:26:09 +00:00	action	zap http://172.28.10.10:3000	rejected	demo-analyst	intrusive active scan not needed for this demo
2026-11-04T17:26:09 +00:00	action	zap http://172.28.10.11:80	rejected	demo-analyst	intrusive active scan not needed for this demo
2026-11-04T17:26:09 +00:00	action	zap http://172.28.10.12:80	rejected	demo-analyst	intrusive active scan not needed for this demo
2026-11-04T17:26:10 +00:00	action	metasploit 172.28.10.12	approved	demo-analyst	lab-only, non-destructive check

6.5 Assessment timestamps

Event	UTC
Assessment created	2026-11-04T17:26:09+00:00
First tool activity	2026-11-04T17:26:09+00:00
Last tool activity	2026-11-04T17:26:10+00:00
Report generated	2026-11-04T17:26:10+00:00

SYNTHETIC TEST DATA

Appendix A — Integration Status Matrix

Tool	Status	How	Known limitations
Nmap	Live + Import	CLI subprocess, XML (-oX) parsing; safe NSE scripts only	No OS detection by default; UDP not scanned.
Nikto	Live + Import	CLI subprocess, XML output; DoS tuning excluded (-Tuning x6)	Nikto does not rate severity: agent classifies and labels it.
OWASP ZAP	Live + Import	ZAP REST API (daemon): spider + passive; active scan only after explicit approval	No authenticated scanning contexts configured.
OpenVAS / Greenbone	Import (Live: experimental)	Greenbone XML report import; optional python-gvm live mode	Live mode untested outside a GVM container; import is the supported path.
Nessus	Import-only	.nessus v2 export import	Nessus Essentials/Pro do not permit API scan launch; we do not claim live scans.
Burp Suite	Import-only (Pro REST API: Planned)	Burp 'Report issues' XML export import	Community edition has no API; analyst-driven testing stays in Burp.
Metasploit	Live (approval-gated, check/scanner only)	msfrpcd RPC or msfconsole; curated non-destructive modules; `check` for exploit modules	Never runs payloads or autonomous exploitation.

Appendix B — Agent decision trace (excerpt)

Time	Type	Decision / rationale
2026-11-04T17:26:09 +00:00	plan	Initial plan: 1 reconnaissance action(s); follow-up tools are chosen only after recon evidence arrives.
2026-11-04T17:26:09 +00:00	failure	nmap on 172.28.10.0/24 -> unavailable: 'nmap' not found on PATH. Without Nmap the service inventory is incomplete; imported scanner results are still correlated.
2026-11-04T17:26:09 +00:00	next-step	Queued: nikto -> http://172.28.10.10:3000. Nmap (JOB-f50bbe04) observed '3000/tcp http Node.js Express framework'. Nikto checks this web server for misconfigurations, dangerous files and outdated server software.
2026-11-04T17:26:09 +00:00	next-step	Queued: zap -> http://172.28.10.10:3000. Nmap (JOB-f50bbe04) observed '3000/tcp http Node.js Express framework'. ZAP spider + passive scan covers application-layer issues (headers, cookies, info leaks) Nikto does not.
2026-11-04T17:26:09 +00:00	next-step	Proposed (needs approval): zap -> http://172.28.10.10:3000. Thorough assessment requested: ZAP active scan sends attack payloads (SQLi/XSS probes) to http://172.28.10.10:3000. Intrusive -> needs explicit approval.
2026-11-04T17:26:09 +00:00	next-step	Queued: nmap -> 172.28.10.10. Targeted safe NSE checks (http-methods) on ports [3000] because those services were observed open; this verifies configuration directly rather than guessing from banners.
2026-11-04T17:26:09 +00:00	next-step	Queued: nikto -> http://172.28.10.11:80. Nmap (JOB-f50bbe04) observed '80/tcp http Apache httpd 2.4.25'. Nikto checks this web server for misconfigurations, dangerous files and outdated server software.
2026-11-04T17:26:09 +00:00	next-step	Queued: zap -> http://172.28.10.11:80. Nmap (JOB-f50bbe04) observed '80/tcp http Apache httpd 2.4.25'. ZAP spider + passive scan covers application-layer issues (headers, cookies, info leaks) Nikto does not.
2026-11-04T17:26:09 +00:00	next-step	Proposed (needs approval): zap -> http://172.28.10.11:80. Thorough assessment requested: ZAP active scan sends attack payloads (SQLi/XSS probes) to http://172.28.10.11:80. Intrusive -> needs explicit approval.
2026-11-04T17:26:09 +00:00	next-step	Queued: nmap -> 172.28.10.11. Targeted safe NSE checks (http-methods) on ports [80] because those services were observed open; this verifies configuration directly rather than guessing from banners.
2026-11-04T17:26:09 +00:00	next-step	Queued: nikto -> http://172.28.10.12:80. Nmap (JOB-f50bbe04) observed '80/tcp http Apache httpd 2.2.8'. Nikto checks this web server for misconfigurations, dangerous files and outdated server software.
2026-11-04T17:26:09 +00:00	next-step	Queued: zap -> http://172.28.10.12:80. Nmap (JOB-f50bbe04) observed '80/tcp http Apache httpd 2.2.8'. ZAP spider + passive scan covers application-layer issues (headers, cookies, info leaks) Nikto does not.
2026-11-04T17:26:09 +00:00	next-step	Proposed (needs approval): zap -> http://172.28.10.12:80. Thorough assessment requested: ZAP active scan sends attack payloads (SQLi/XSS probes) to http://172.28.10.12:80. Intrusive -> needs explicit approval.
2026-11-04T17:26:09 +00:00	next-step	Queued: nmap -> 172.28.10.12. Targeted safe NSE checks (ftp-anon, http-methods, smb-security-mode, smb-vuln-ms17-010, smb2-security-mode) on ports [21, 80, 445] because those services were observed open; this verifies configuration directly rather than guessing from banners.

SYNTHETIC TEST DATA

Time	Type	Decision / rationale
2026-11-04T17:26:09 +00:00	next-step	Proposed (needs approval): metasploit -> 172.28.10.12. F-25DD5E 'Anonymous FTP login permitted' is SUSPECTED (confidence 0.95, sources: nmap). Non-destructive module auxiliary/scanner/ftp/anonymous can confirm or refute it; confirmation raises exploitability in the risk score, refutation lowers confidence.
2026-11-04T17:26:09 +00:00	failure	nikto on http://172.28.10.10:3000 -> unavailable: 'nikto' not found on PATH. Web server coverage now relies on ZAP; gap recorded as a limitation.
2026-11-04T17:26:09 +00:00	failure	zap on http://172.28.10.10:3000 -> unavailable: ZAP API not reachable at http://localhost:8090 (ConnectionError). Web application coverage now relies on Nikto (+ any Burp import); gap recorded as a limitation.
2026-11-04T17:26:09 +00:00	failure	nmap on 172.28.10.10 -> unavailable: 'nmap' not found on PATH. Without Nmap the service inventory is incomplete; imported scanner results are still correlated.
2026-11-04T17:26:09 +00:00	failure	nikto on http://172.28.10.11:80 -> unavailable: 'nikto' not found on PATH. Web server coverage now relies on ZAP; gap recorded as a limitation.
2026-11-04T17:26:09 +00:00	failure	zap on http://172.28.10.11:80 -> unavailable: ZAP API not reachable at http://localhost:8090 (ConnectionError). Web application coverage now relies on Nikto (+ any Burp import); gap recorded as a limitation.
2026-11-04T17:26:09 +00:00	failure	nmap on 172.28.10.11 -> unavailable: 'nmap' not found on PATH. Without Nmap the service inventory is incomplete; imported scanner results are still correlated.
2026-11-04T17:26:09 +00:00	failure	nikto on http://172.28.10.12:80 -> unavailable: 'nikto' not found on PATH. Web server coverage now relies on ZAP; gap recorded as a limitation.
2026-11-04T17:26:09 +00:00	failure	zap on http://172.28.10.12:80 -> unavailable: ZAP API not reachable at http://localhost:8090 (ConnectionError). Web application coverage now relies on Nikto (+ any Burp import); gap recorded as a limitation.
2026-11-04T17:26:09 +00:00	failure	nmap on 172.28.10.12 -> unavailable: 'nmap' not found on PATH. Without Nmap the service inventory is incomplete; imported scanner results are still correlated.
2026-11-04T17:26:10 +00:00	failure	metasploit on 172.28.10.12 -> unavailable: 'msfconsole' not found on PATH. Finding stays 'suspected'; analyst may validate manually.

Appendix C — Findings triaged as false positive

Finding	Asset	Sources	Reason
Absence of anti-CSRF tokens	172.28.10.11	zap	analyst override -> false_positive by demo-analyst: DVWA CSRF page is intentionally token-less in low security mode; out of test objective

Appendix D — Audit trail integrity

Hash-chained audit log: VALID (76 entries). File: data/assessments/ASM-8a3e4738/audit.jsonl

SYNTHETIC TEST DATA